

ADDIS ABABA UNIVERSITY

College of Technology and Built Environment
School of Electrical and Computer Engineering

PHASE I PROPOSAL

OWASP Juice Shop: Environment Exploration & Strategy

PROJECT NAME GROUP 10 PENTEST- ING INITIATIVE

Course Title: Computer and Network Security
Course Code: ECEG-5212

PREPARED BY (GROUP 10)

Name	ID Number
Lemi Negeso	UGR/1087/15
Ayalkbet Teketel	UGR/7646/15
Bereket Getachew	UGR/1621/15
Melkam Ayehu	UGR/9379/13
Solomon Hizkiel	UGR/2559/15
Fulea Tsegaye	UGR/6125/15

Submitted to: Lecturer Kinde M.
Date of Submission: May 30, 2026

Executive Summary

This Phase I Proposal outlines the environmental exploration of the **OWASP Juice Shop**, a modern web application designed with intentional security vulnerabilities. Group 10 has selected this environment due to its sophisticated architecture (Angular/Node.js) and its comprehensive coverage of the OWASP Top 10 risks. This document details our team structure, the target's technology stack, initial reconnaissance findings, and our planned penetration testing methodology.

Contents

Contents	ii
1 Introduction	1
1.1 Background and Objectives	1
1.2 Why OWASP Juice Shop?	1
2 Team Composition and Roles	2
3 Environment Exploration (Activity A)	3
3.1 Target Overview	3
3.2 Architecture and Tech Stack	3
3.3 Technology Fingerprinting	3
3.4 Initial Reconnaissance Findings	4
3.4.1 Directory Enumeration	4
3.4.2 HTTP Header Analysis	4
4 Attack Surface Mapping	5
4.1 Identified Attack Vectors	5
4.2 API Exploration	5
5 Methodology and Toolset	6
5.1 Penetration Testing Phases	6
5.2 Software Inventory	6
6 Project Timeline and Milestones	7
6.1 Phase I and II Schedule	7
6.2 Activity Milestones	7
7 Conclusion	8

Bibliography

9

1 Introduction

1.1 Background and Objectives

In the field of cybersecurity, theoretical knowledge must be tempered by practical experience. The **ECEG-5212** course project provides this opportunity by tasking teams with exploring and securing complex environments. Our team has selected the OWASP Juice Shop as our target range.

The primary objectives of this phase are:

- To map the attack surface of the Juice Shop.
- To identify the technologies used in the front-end and back-end.
- To establish a collaborative workflow for the team.

1.2 Why OWASP Juice Shop?

Unlike older environments like DVWA, the Juice Shop utilizes a **Single Page Application (SPA)** architecture. It provides:

- Over 100 challenges across multiple difficulty levels.
- A realistic e-commerce scenario including user accounts, shopping baskets, and reviews.
- Modern security features like JWT authentication and OAuth 2.0.

2 Team Composition and Roles

Effective penetration testing requires a diverse set of skills. Group 10 has distributed responsibilities as follows:

Table 2.1: Team Roles and Responsibilities

Role	Member	Primary Responsibilities
Project Manager	Lemi Negeso	Task scheduling, quality control, and Phase I/II submission management.
Researcher	Ayalkbet Teketel	Architecture analysis, technology fingerprinting, and documentation of CVEs.
Analyst	Bereket Getachew	Traffic analysis, API endpoint mapping, and vulnerability prioritization.
Tester	Melkam Ayehu	Manual/Automated exploitation, payload crafting, and evidence collection.
Documenter	Solomon Hizkiel	Maintaining the technical lab notebook and drafting the final reports.
Presenter	Fulea Tsegaye	Developing presentation slides and leading the live demonstration.

3 Environment Exploration (Activity A)

3.1 Target Overview

The OWASP Juice Shop is an e-commerce application selling various "juices" and related products. It is built using a modern JavaScript stack.

3.2 Architecture and Tech Stack

Our initial exploration reveals a **three-tier architecture**:

1. **Presentation Layer:** Built with **Angular** (v12+). Most logic is handled client-side.
2. **Application Layer:** A **Node.js** server using the **Express** framework.
3. **Data Layer:** A **SQLite** database for persistence, often interacted with via Sequelize ORM.

3.3 Technology Fingerprinting

Using tools like **Wappalyzer** and **Nikto**, we identified the following components:

Identified Components

- **Web Server:** Express (Node.js)
- **Framework:** Angular
- **API Type:** RESTful JSON API
- **Database:** SQLite (Relational)
- **Authentication:** JSON Web Tokens (JWT)

3.4 Initial Reconnaissance Findings

Our reconnaissance phase involved both passive and active information gathering:

3.4.1 Directory Enumeration

Using `gobuster`, we discovered several sensitive directories:

- `/ftp`: Contains public-facing files and potentially sensitive backups.
- `/administration`: A hidden admin dashboard.
- `/api`: The base for all back-end service calls.

3.4.2 HTTP Header Analysis

We observed the following headers during initial request interceptions:

- **Server:** `Microsoft-IIS/8.5` (Potential spoofing/misconfiguration)
- **X-Content-Type-Options:** `nosniff`
- **Missing:** `Content-Security-Policy` (CSP) and `X-Frame-Options`, suggesting susceptibility to XSS and Clickjacking.

4 Attack Surface Mapping

4.1 Identified Attack Vectors

Based on our Activity A exploration, we have mapped the following attack vectors:

Table 4.1: Mapped Attack Surfaces

Surface	Potential Vulnerability	Complexity
Login Page	SQL Injection / NoSQL Injection	Medium
Search Bar	Reflected XSS	Low
File Upload	Remote Code Execution (RCE) via Unfiltered Uploads	High
User Feedback	Stored XSS	Medium
Review System	IDOR (Insecure Direct Object Reference)	Medium
Basket/Cart	Parameter Tampering (Price Manipulation)	Low

4.2 API Exploration

The application heavily relies on an API. We captured several endpoints using Burp Suite:

- GET /rest/products/search?q=: Suspected for SQLi.
- POST /api/Users/login: Suspected for JWT authentication bypasses.
- GET /api/BasketItems: Suspected for IDOR.

5 Methodology and Toolset

5.1 Penetration Testing Phases

Group 10 will follow the **OWASP Web Security Testing Guide (WSTG)**:

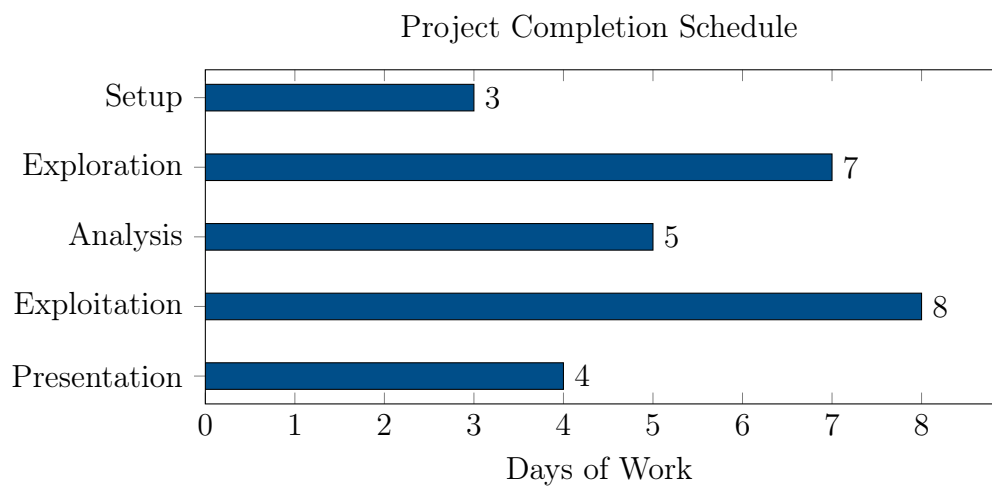
1. **Reconnaissance:** (Completed in Phase I)
2. **Vulnerability Analysis:** Scoring and prioritizing findings (Phase II).
3. **Exploitation:** Gaining access and demonstrating impact (Phase II).
4. **Reporting:** Detailed mitigation strategies (Phase II).

5.2 Software Inventory

Category	Tools
Proxy & Interception	Burp Suite Community Edition, OWASP ZAP
Enumeration	Nmap, Gobuster, Nikto
Automated Injection	SQLMap
Browser Analysis	Firefox DevTools, Wappalyzer
JWT Manipulation	JWT.io, Burp JWT Editor extension

6 Project Timeline and Milestones

6.1 Phase I and II Schedule



6.2 Activity Milestones

- **M1 (May 10):** Environment setup on local Docker containers.
- **M2 (May 30):** Completion of Activity A and Phase I Submission.
- **M3 (June 10):** Successful exploitation of at least 5 Critical vulnerabilities.
- **M4 (June 20):** Final Report and Presentation completion.

7 Conclusion

Phase I has successfully established the foundation for our penetration testing initiative. By exploring the **OWASP Juice Shop**, Group 10 has identified a rich target environment with diverse vulnerabilities ranging from simple XSS to complex JWT exploits. Our team is fully equipped with the necessary tools and a structured methodology to proceed to **Phase II: Exploitation and Remediation**.

Bibliography

- [1] OWASP Foundation, *OWASP Juice Shop Project*, 2024. [Online]. Available: <https://owasp.org/www-project-juice-shop/>
- [2] OWASP Foundation, *Web Security Testing Guide*, v4.2.
- [3] Node.js Foundation, *Node.js Documentation*, 2024.